How gcc-Linux-implementation works for code-injection-detection
https://github.com/code-injection-detection/gcc-Linux-Implementation
12-October-2016

This is an unofficial guide. Many things are temporary and about to change. Also, this is a high-level approch and we do not delve into the details.

Ok let's start:

Directory structure:
1) src/: Inside there are the java source files than manipulate the assembly and the final executable
2) samples/: In there are the other files that emulate the secure machine. Of course "samples" is not a good name, and that is something that will soon change.
3) bin/: This directory does not exist on github. In there there are the java class files (that Eclipse produces automatically). Someone that does not use Eclipse should compile the .java files in the src/ directory and move them inside the bin/ directory. To save the hassle, a script does it automatically, if the java compiler (javac) is installed.

Before we enumerate the files one by one, let's talk about the procedure that is followed.
First, we have a .c file that contains ALL of the code (except the functions of the standard C library that it #includes). That code includes the main() function, test functions, the secure heap implementation, the secure stack implementation and the verification procedure.
That code is the compiled into assembly. The output looks like this:

set_correct_defines.py | Helloworldadd.s | Helloworldadd_sec.s

```
    movq    24(%rax), %rax
    movl    $2, %esi
    movq    %rax, %rdi
    call    get_stack_int_array_element
    leal    1(%rax), %edx
    movq    -24(%rbp), %rax
    movq    16(%rax), %rax
    movq    24(%rax), %rax
    movl    $2, %esi
    movq    %rax, %rdi
    call    set_stack_int_array_element
.L679:
    movq    -24(%rbp), %rax
    movq    16(%rax), %rax
    movq    24(%rax), %rax
    movl    $2, %esi
    movq    %rax, %rdi
    call    get_stack_int_array_element
    movl    %eax, %ebx
    movq    -24(%rbp), %rax
```

Now a java program (Secure_Assembly.java) will change that assembly into an assembly that has NOP instructions inserted among groups of regular instructions. For example, if 7 NOPs are inserted between groups of 1 regular instruction, the new assembly file looks like:

set_correct_defines.py | Helloworldadd.s | Helloworldadd_sec.s

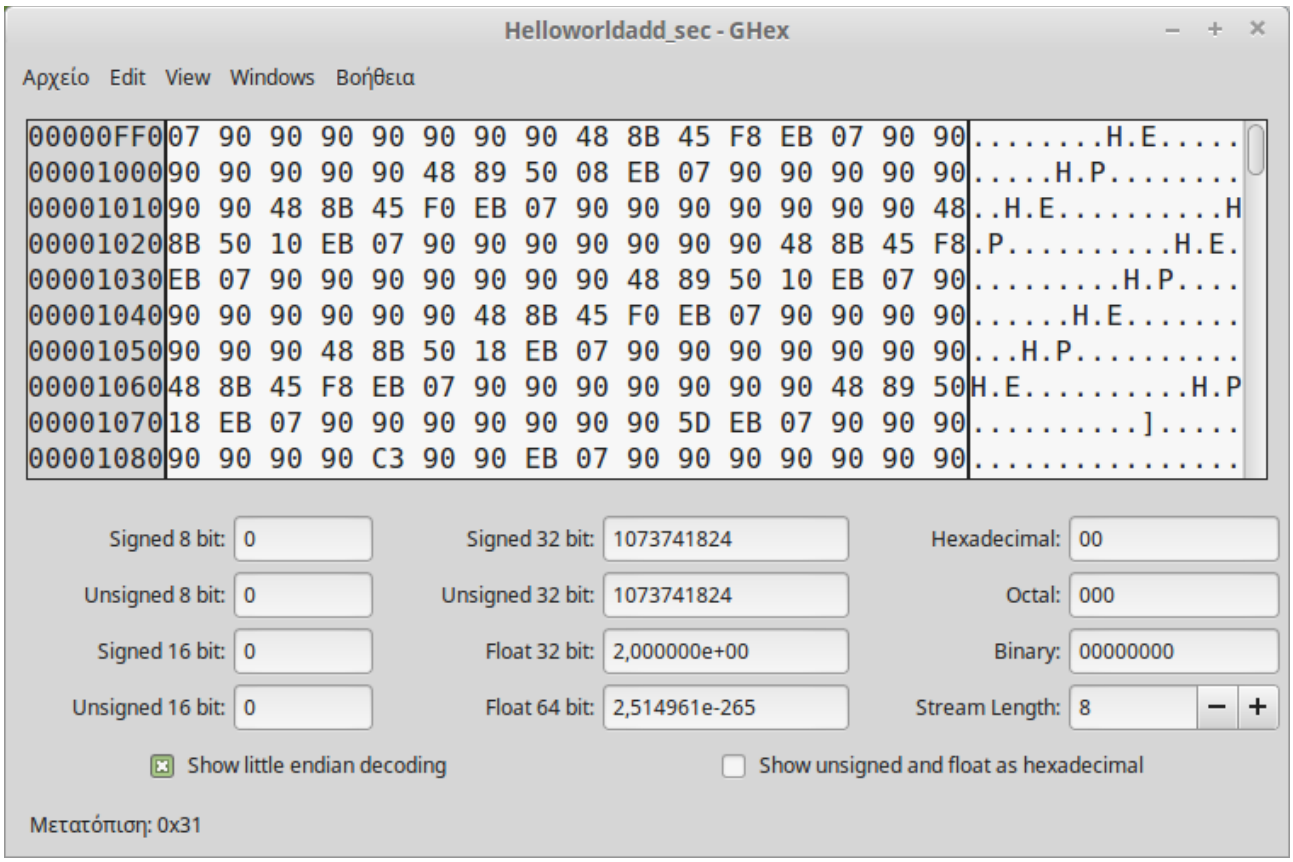
```
NOP
NOP
.UNIQUE8537:
    call    set_stack_int_array_element
.L679:
 jmp .UNIQUE8538
NOP
NOP
NOP
NOP
NOP
NOP
NOP
.UNIQUE8538:
    movq    -24(%rbp), %rax
 jmp .UNIQUE8539
NOP
NOP
NOP
NOP
NOP
NOP
NOP
.UNIQUE8539:
    movq    16(%rax), %rax
```

In this example, the 7 NOPs correspond to 5 places for the keys to be put (the final 5 NOPs) , and 2 places for canary values that actually depict that “hey, keys are following”, in order to help the verification procedure.

That assembly file is then assembled into an executable, without any optimizations (so as not to remove the NOPs or the command order).

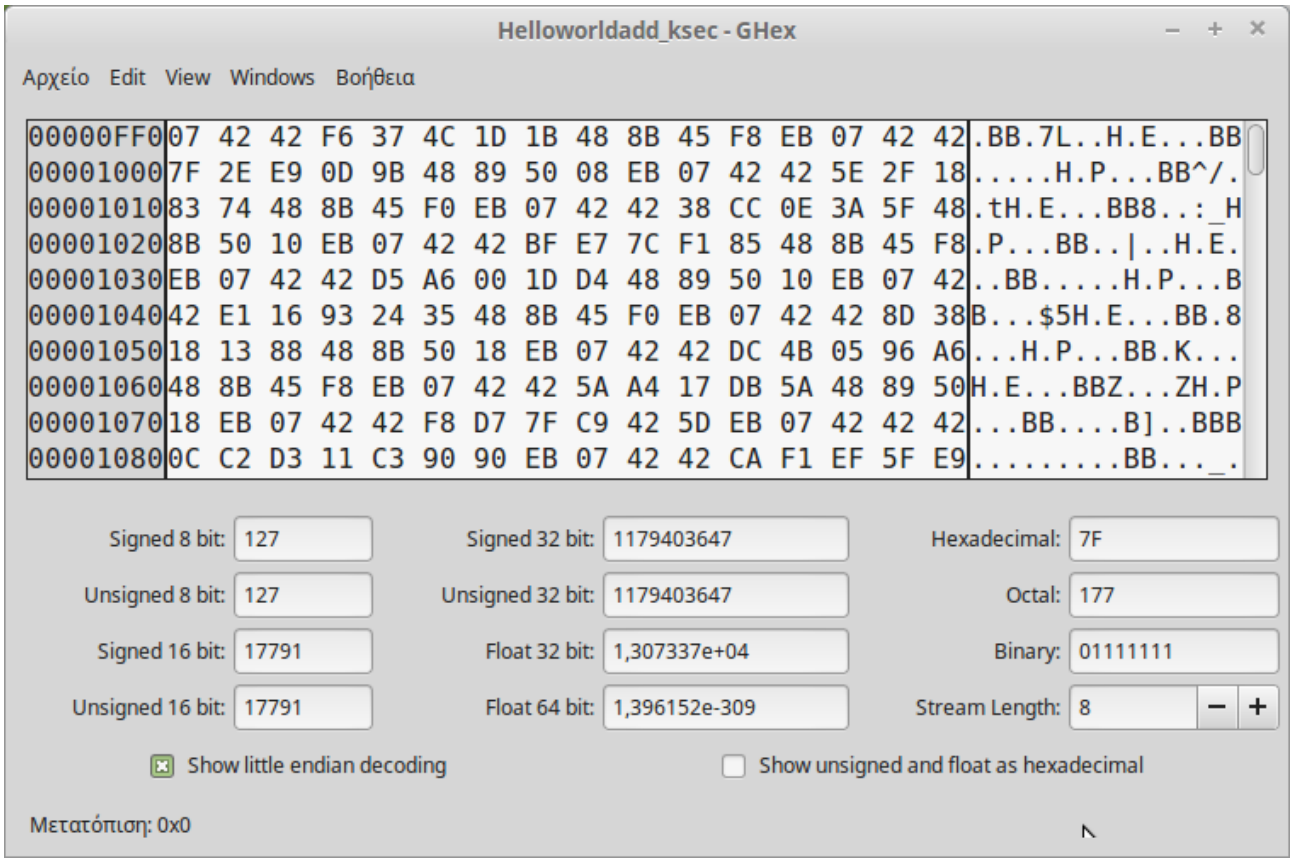
After that, another java program (Secure_Machine_Code.java) takes the produced binary, searches it byte-by-byte to find the pattern “jump +7 bytes and 7 NOPs are following” and replaces the NOP bytes with canaries and keyshares. The same java program also produces keyshares that will be inserted into the secure heap and secure stack. These ones are saved into the corresponding files. Finally, it outputs the XOR of all the keyshares, that are the keys that must be matched by the verification procedure.

As an example, the executable program with the NOPs (byte 0x90) looks like this:



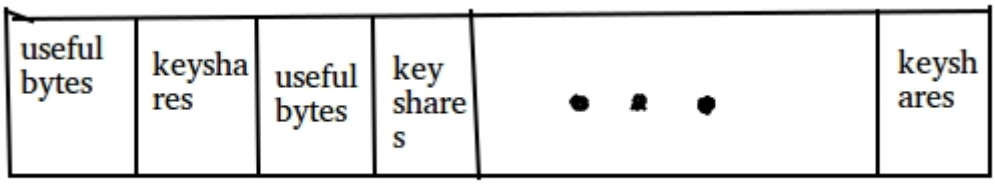
The JMP 07 instruction (EB 07) is clear, with the NOPs that follow it.

Same program with the NOPs replaced. The 2 canary values are 2 bytes of 0x42:



This is the final executable. When it runs, it initialises secure heap and stack (using the files with the keyshares), installs a signal handler for SIGUSR1 which, when invoked, starts the verification procedure, and then continues execution to perform the tests. Update: Along with the signal handler, it starts a listening socket in order to accept inbound connections from the outside that seek to verify the code.

The secure heap and secure stack are structured in the following way:



Important notes: a)The MACs have not been added yet.
b)The “useful bytes” chunks are same sized. The same applies to the keyshares chunks.
c)Every access to the secure stack or heap is done through the proper secure_* functions.

The verification procedure starts from the start of the code, and up until the end of the code searches for the sequence “EB 07 42 42” (in this example, not in every case), and calculates the keyshares from the bytes after that sequence. After that it fetches the keyshares from the secure heap and the secure stack. It XORs all the bytes and presents the final keys, which must be the same with the ones printed by the second java program.

Now let's take a glance at some of the most important files.

automate.sh: It's the bash script that does all of the preprocessing , given some parameters by the user.
a)It transforms the headers with the parameters that the user requested (for example the size of the secure heap)
b)It transforms directives inside .c files that the user has written, into valid C code. These directives are about the secure stack. a) and b) are performed with a python script.
c)Compiles the program into assembly.
d)Adds NOPs to assembly (with java)
e)Assembles the program to create an executable
f)Replaces NOPs with keys (with java)

set_correct_defines.py: This python program changes the defined values inside the

headers_needed_template.h file (before the compilation), and parses the user's directives inside the general_tests_template.c file. With these, it produces valid C code.

(Inside templates directory:)
***template.{c,h}**: These are the template files that a programmer should edit. If a program X.{c,h} has a corresponding X_template.{c,h}, this means that the programmer should edit the template. The X.{c,h} program is used for the actual compilation, but that is after the code of the corresponding template is copied over it, and it is processed by the above python program. So, any changes to the X.{c,h} program will be OVERWRITTEN next time the automate.sh script is invoked. Update: Now the templates are in a separate directory.

Helloworldadd.c : This is the main program. It's name comes from the “HelloWorld” and an “add” test function. Its name is awful and will be changed. All it does is test the secure implementation. It includes the “.c” files of the secure heap and stack, the test files and the verification procedure. All these are in the “functions_needed.c” file. It includes C files and not .h files because it is easier for the java program that inserts NOPs afterwards to deal with one and not multiple programs. After the includes and the initialization of the secure stuff, it performs the tests.

stack_manager_template.c
memory_manager_template.c
verification_procedure_template.c: They implement the secure stack and heap, and the verification procedure. More detail in a separate document.

memory_manager_test_suite.c
stack_manager_test_suite.c
general_tests_template.c: They have some tests. They are nothing important. Someone should only look there (especially in the general tests) to see how to invoke the secure functions. More detail in a separate document.

Makefile: The Makefile for the C programs. The interesting thing there is the FLAGS_to_assembly, in which optimizations can be put.

So, to end the high-level approach, let's demonstrate an example run:

Inside the main() function we have:

```
...
init_heap_and_stack_mem();
install_signal_handler();
...
int hanoi_up_to=25;
TEST_NORMAL_AND_SECURE_TIME( towers of Hanoi, towerOfHanoi(hanoi_up_to,'A','C','B');
,towerOfHanoi_secure_using_template( hanoi_up_to,'A','C','B'); )
```

```
printf("\n");
printf("Going to find keyshares.\n");
find_keyshares(); //for verification
free_heap_and_stack_memory();
```

The TEST_NORMAL_AND_SECURE_TIME is a macro that does what it says.

We can invoke the automate.sh script with the following parameters:

./automate.sh <a> <b> <c> <d> <e> <f> <g>
Where: a=number_of_interleaved keys in code, b=number_of grouped instructions in code
c=number of canary values before keyshares in code, to denote keyshare presence
d=number of grouped useful bytes in heap memory, e=total bytes to (try to) pre-allocate in heap memory
f=number of grouped useful bytes in stack memory, g=total bytes to (try to) pre-allocate in stack memory
Example: ./automate.sh 5 1 2 4 2048 4 1024

For the hanoi towers we will give some more stack memory. Lets say 8192 bytes.

```
./automate.sh 5 1 2 4 2048 4 8192
NUM_OF_INTERLEAVED_KEYS: 5
NUM_OF_GROUPED_INSTRUCTIONS: 1
NUM_OF_GROUPED_USEFUL_BYTES: 4
NUM_OF_TOTAL_BYTES_ALLOC: 2048
NUM_OF_CANARIES: 2
NUM_OF_GROUPED_USEFUL_STACK_BYTES: 4
NUM_OF_TOTAL_STACK_BYTES_ALLOC: 8192

Changing defines according to input...
Changed defines.
Copying templates to target files
Copied templates
Compiling....
gcc -O0 Helloworldadd.c -S -lm
gcc -O0 Helloworldadd.s -c -o Helloworldadd.o -lm
gcc -O0 Helloworldadd.o -o Helloworldadd -lm
Compiled.
Inserting NOPs into assembly...
NOPs inserted.
Assembling code with NOPs...
gcc -O0 Helloworldadd_sec.s -c -o Helloworldadd_sec.o -lm
gcc -O0 Helloworldadd_sec.o -o Helloworldadd_sec -lm
Assembled.
Replacing NOPs with keys...

Keyshare 0 : 0xF2
Keyshare 1 : 0xF5
Keyshare 2 : 0xA5
Keyshare 3 : 0x77
Keyshare 4 : 0x62
Number of nop groups replaced: 9999
NOPs replaced with keys.
```

And running the executable will yield:

```
./Helloworldadd_ksec
Initializing heap memory
bytes_to_allocate_on_start:2048
Init_mem, alloc+key insertion
Whoops. We need to allocate a bit more space.
If successful, total bytes allocated:2056
Initializing stack memory
Stack bytes_to_allocate_on_start:8192
Init_stack_mem, alloc+key insertion
Stack: Whoops. We need to allocate a bit more space.
If successful, total bytes allocated:8194
Installing signal handler
Signal handler installed
My pid=13566
K=6
n=10
main is at 0x420a31

Calculating time for towers of Hanoi. Normal towers of Hanoi:

Normal towers of Hanoi:0.504955 cpu seconds
Secure towers of Hanoi:

Normal towers of Hanoi time:0.504955 cpu seconds
Secure towers of Hanoi time:29.8955 cpu seconds

Ratio: 59.2042 times slowdown

Going to find keyshares.

key no0=0xf2
key no1=0xf5
key no2=0xa5
key no3=0x77
key no4=0x62
```